

Security Risk Assessment Report

Social Media Organization Data Breach

Analyst: Mohammad

Organization type: Social media company

Incident context: Major data breach compromising customer personal information (names, addresses)

Scenario

The organization recently experienced a major data breach that compromised customers' personal information. An inspection of the network identified four major vulnerabilities:

- Employees share passwords with one another.
- The admin password for the database is still set to its default value.
- The firewall has no rules in place to filter inbound or outbound traffic.
- Multifactor authentication (MFA) is not implemented anywhere on the network.

Part 1: Selected Hardening Tools and Methods

Three hardening tools were selected, chosen so that together they address all four identified vulnerabilities:

- Multifactor Authentication (MFA)
- Password Policies
- Firewall Maintenance

Part 2: Recommendations and Explanation

1. Multifactor Authentication (MFA)

Addresses vulnerabilities: Employees sharing passwords; absence of MFA

MFA requires a user to verify their identity through two or more methods — typically a password combined with a one-time passcode (OTP), fingerprint, or other secondary factor. This directly addresses two vulnerabilities at once. First, it solves the missing-MFA vulnerability outright. Second, it significantly reduces the risk created by password sharing: even if an employee shares their password with a coworker, or a password is stolen, the second authentication factor is tied to a specific device or person and cannot be easily shared or replicated. A shared password alone would no longer be sufficient to access the system.

Implementation frequency: MFA is typically set up once per account and then maintained going forward, rather than requiring repeated reconfiguration. Periodic reviews should confirm MFA remains enabled for all accounts, especially newly created ones.

2. Password Policies

Addresses vulnerability: Default admin password on the database

Implementing a password policy ensures that default credentials are never left in place after account or system setup. Current NIST guidance for password policies emphasizes securely storing passwords using salting and hashing, rather than relying solely on complexity rules or forced periodic changes. Applying this policy to the database admin account specifically would have required a unique, non-default password

to be set at the time of configuration, removing the exact weakness that contributed to the breach.

Implementation frequency: Password policy enforcement is typically configured once at the system/account level, but should be reviewed periodically (e.g., during routine security audits) to confirm no accounts have reverted to default or weak credentials.

3. Firewall Maintenance

Addresses vulnerability: Firewall has no rules in place to filter traffic

Firewall maintenance involves regularly checking and updating firewall security configurations, including establishing rules that filter inbound and outbound traffic based on port, protocol, and source/destination. Without any filtering rules in place, the organization's firewall is providing effectively no protection — any traffic, malicious or not, can pass through unchecked. Establishing and maintaining proper filtering rules directly closes this gap, and ongoing maintenance helps the organization adapt its rules in response to new or evolving threats, including various DDoS attack patterns.

Implementation frequency: Firewall maintenance should be performed on a regular, ongoing basis (e.g., a recurring scheduled review), with additional rule updates made promptly in response to any specific security event or abnormal traffic pattern.

Summary

Together, these three hardening measures address all four identified vulnerabilities: MFA mitigates both the password-sharing risk and the lack of multifactor verification; password policy enforcement eliminates the default admin password weakness; and firewall maintenance closes the gap left by an unfiltered network perimeter. Implementing these measures in combination reflects a defense-in-depth approach, reducing the organization's overall risk of experiencing a similar breach in the future.